

SecurityScorecard API Reference

Overview

The SecurityScorecard API enables programmatic interaction with the platform for cybersecurity risk management, including retrieving scores, issues, portfolios, and more. It supports integration for data retrieval, resource management, and threat intelligence via Attack Surface Intelligence (ASI). API access requires a paid plan; free accounts do not have access. Core concepts include portfolios (collections of companies), scorecards (security ratings for companies), and issues (specific security findings). The API is versioned, with major versions in URLs (e.g., /v1, /v2) for breaking changes.

Base URL

<https://api.securityscorecard.io>

Authentication

All endpoints require authentication via an API token. Include the header: `Authorization: Token <YOUR_API_KEY>`. API keys are generated in the platform under `My Settings > API` tab. Keys do not expire but can be revoked by generating a new one. Use HTTPS only; HTTP requests are rejected. Supported TLS: 1.2 and 1.3.

Headers

- `Content-Type: application/json` for JSON requests/responses (default unless specified, e.g., CSV/PDF for reports).
- `Accepts-Version` for granular versioning.

Rate Limits

- 5,000 requests per hour per client, over a rolling 60-minute window.

- Exceeding limits returns 429 Too Many Requests with `Retry-After` header (seconds to wait).
- Best practices: Batch requests, implement exponential backoff, respect `Retry-After`.

Pagination

Supports page-based and cursor-based for large collections.

- **Page-Based:** Parameters `page` (int, default 1), `size` (int, default/max 50). Response: `{entries: [], total: int, size: int, page: int}`. Use `Link` header for next page.
- **Cursor-Based:** Parameters `limit` (int, e.g., 50), `cursor` (string from previous `next_cursor`). Response: `{entries: [], next_cursor: string}`. No `next_cursor` indicates end.
- For very large data: Asynchronous report generation (e.g., POST `/reports/full-dump`).

Errors

Categorized into Content (4xx), Network, and Server (5xx) errors.

- **400 Bad Request:** Invalid format; check values.

- **401 Unauthorized:** Missing/invalid API key; verify header.
- **403 Forbidden:** Insufficient permissions; check access.
- **404 Not Found:** Resource missing; verify ID/URL.
- **405 Method Not Allowed:** Wrong HTTP method; check docs.
- **409 Conflict:** State conflict; refresh and retry.
- **413 Payload Too Large:** Exceeds size; reduce data.
- **422 Unprocessable Entity:** Invalid data; fix fields.
- **429 Too Many Requests:** Rate exceeded; wait per `Retry-After`.
- **Network Errors:** Timeout/interruption; retry after network check.
- **500 Internal Server Error:** Server issue; retry with backoff, check status page.
- **502 Bad Gateway:** Invalid upstream; retry, contact support.
- **503 Service Unavailable:** Temporary overload; retry.
- **504 Gateway Timeout:** No timely response; retry.

Backwards Compatibility

- Major versions in URL (e.g., /v1) for breaking changes.
- Semantic Versioning: MAJOR (breaking), MINOR (new features, compatible), PATCH (fixes, compatible).
- Compatible changes: New endpoints/params/fields, logic updates, reordered fields, new webhooks.
- Breaking: Removed/renamed fields, type changes, new required params.
- Deprecation: Announced 6+ months ahead, supported 6+ months with warnings, then sunset.

Attack Surface Intelligence (ASI) API

Tracks asset connections to threats, CVEs, breaches, malicious reputation, MITRE ATT&CK

HTTPS. Query data lake directly. Use documented endpoints only; undocumented may be blocked. See Knowledge Base for guidance/best practices. Jupyter notebooks available for analysis (GitHub: <https://github.com/securityscorecard/ssc-asi-tools/tree/master/tools/notebooks>).

Endpoints

Inferred from documentation structure. All use base URL, JSON unless noted, authenticated via token. Paths derived from slugs/titles; details limited due to access constraints.

Portfolios

Method	Path	Description	
GET	/portfolios	Get all portfolios you have access to.	

Plans

Method	Path	Description	
PATCH	/plans/overall-score-improvement/{id}	Update partially the overall score improvement plan by ID.	
POST	/plans/overall-score-improvement	Create new overall score improvement plan.	
PATCH	/plans/issue-resolution/{id}	Update partially the issue resolution plan by ID.	
POST	/plans/issue-resolution	Create new issue resolution plan.	
POST	/plans/{id}/guests	Add guests to plan by ID.	

IP/Domain Tags

Method	Path	Description	
--------	------	-------------	--

GET	/api/tag-groups/{id}	Get an IP/domain tag group.
POST	/api/tag-groups	Create a new IP/domain tag group.
DELETE	/api/tag-groups/{id}	Delete an IP/domain tag group.
GET	/api	Get all IP/domain tags.
DELETE	/api/{tagId}	Delete an IP/domain tag.
DELETE	/api/groups/{tagGroupId}/association/{tagId}	Remove IP/domain tag from a IP/domain tag group.
POST	/api/{parentDomain}/domain/{domain}/associate-tags/{tagId}	Add a tag to a domain.
POST	/api/{parentDomain}/ip/{ip}/associate-tags/{tagId}	Add a tag to an IP.
GET	/api/{parentDomain}/domain-related-tags	Get all the domain tags of the parent domain.

Followed Companies

Method	Path	Description 
--------	------	---

GET	/followed-company/{domain}	Get followed company by domain.
POST	/followed-companies/bulk-delete-operation	Execute bulk delete operation on followed companies.
POST	/custom-tags/followed-companies/bulk-create-operation	Associates given tag IDs to given companies.

Assets/Attribution

Method	Path	Description	
GET	/parentDomain}/attribution-log	Get the attribution log for the parent domain.	
POST	/parentDomain}/assets/domains	Get all the domains for the parent domain.	

Reports

Method	Path	Description	
POST	/reports/summary	Generate a Company Summary report. Note: May fail if score calculation is pending.	

Invitations

Method	Path	Description	
POST	/invitations	Create a new invitation for a new user/vendor.	

ASI (Attack Surface Intelligence)

Method	Path	Description	
POST	/asi/facets	ASI facets endpoint (details limited).	

Issues/Search

The /reference/search page lists endpoints for getting specific issues in a scorecard, such as GET for "attack detected" "cdn hosting" "cobalt strike c2 detected" etc. Even

as GET for `attack_detected` , `cdn_hosting` , `covert_strike_c2_detected` , etc. Exact paths/methods not detailed; likely GET `/issues/{type}` or similar.